



24/12/2025

# PROGETTO FINALE MODULO 3



“Analisi delle vulnerabilità e azioni di  
rimedio”

A cura di Fabio Renna



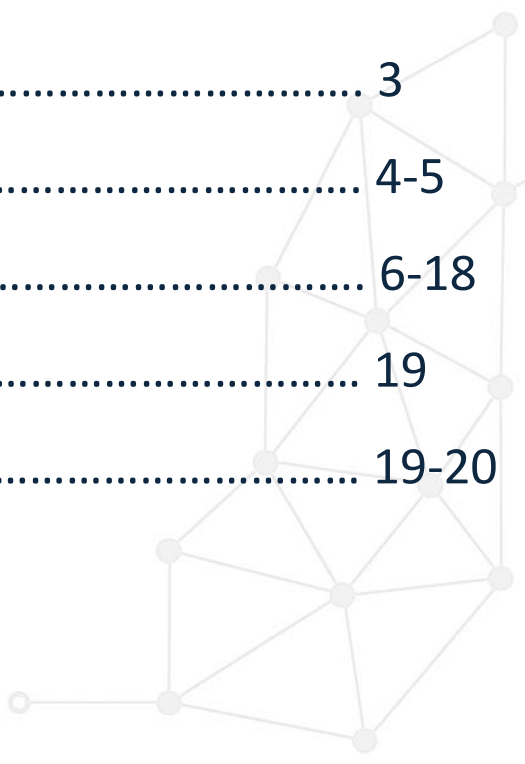
24 DICEMBRE 2025

EPICODE – INSTITUTE OF TECHNOLOGY



# INDICE

|                        |       |
|------------------------|-------|
| Executive Summary..... | 1     |
| Introduzione.....      | 1-2   |
| Obiettivi.....         | 2     |
| Metodologia.....       | 3     |
| Ambiente di Test.....  | 4-5   |
| Proof of Concept.....  | 6-18  |
| Conclusione.....       | 19    |
| Glossario Tecnico..... | 19-20 |



## Executive Summary

Nel corso dell'attività di analisi e remediation è stata eseguita una valutazione di sicurezza sulla macchina **Metasploitable (IP 192.168.50.101)**, con l'obiettivo di identificare vulnerabilità critiche e implementare misure correttive efficaci. La scansione iniziale, effettuata tramite **Nessus**, ha evidenziato numerose debolezze legate a servizi obsoleti, configurazioni insicure e componenti non più supportati dal vendor.

Sono state selezionate quattro vulnerabilità critiche, scelte in base all'impatto sul sistema, alla criticità del rischio e alla possibilità di essere mitigate in un contesto di laboratorio. Le vulnerabilità affrontate hanno riguardato servizi esposti senza adeguati controlli (**VNC e Bind Shell**), protocolli di comunicazione obsoleti (**SSLv2/SSLv3**) e un componente server vulnerabile (**Apache Tomcat AJP/Ghostcat**). Per ciascuna criticità sono state applicate azioni di remediation mirate, che hanno incluso la rigenerazione di credenziali, la disattivazione di servizi insicuri, la chiusura di porte non necessarie e la modifica dei file di configurazione per ridurre la superficie di attacco.

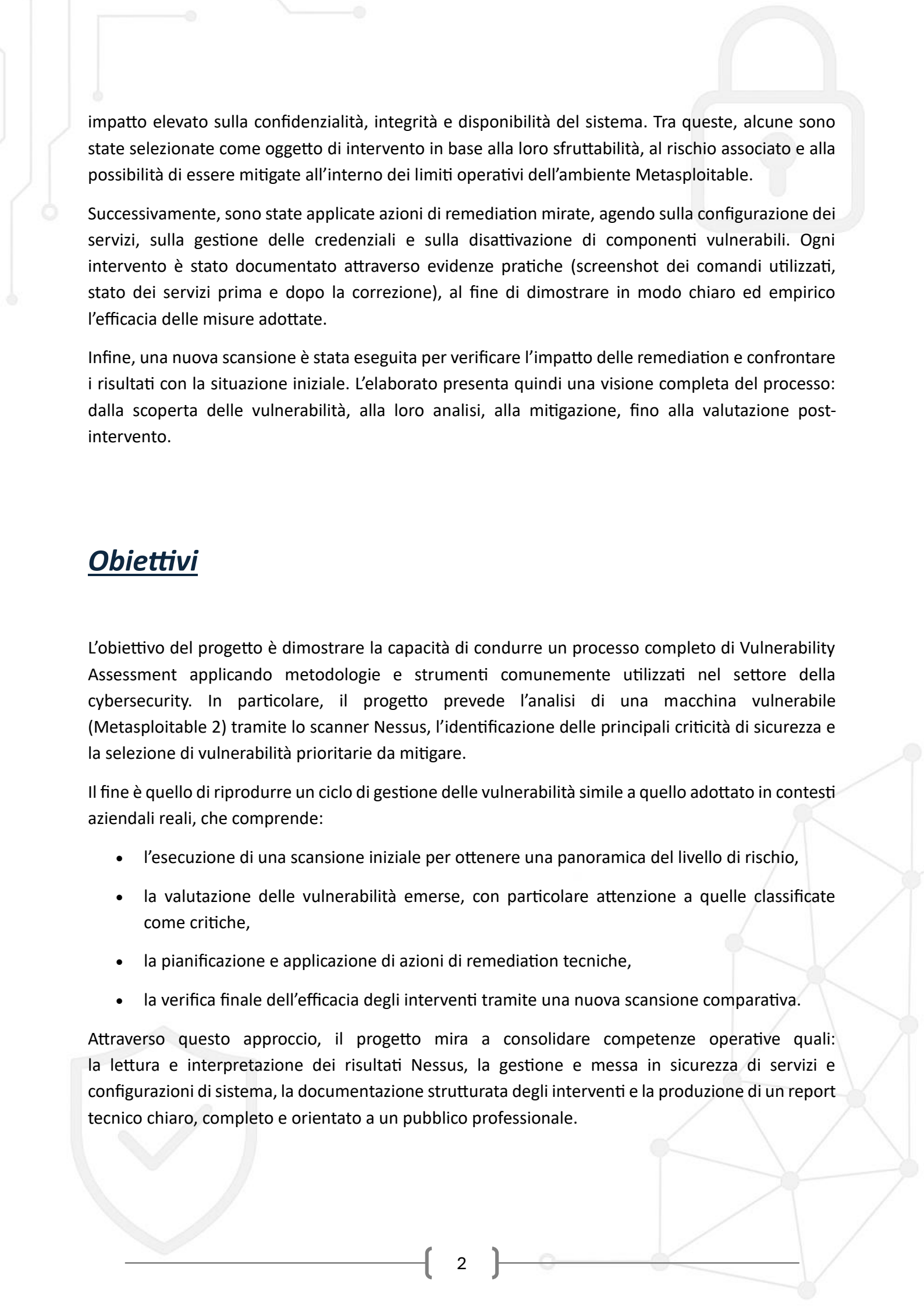
La successiva scansione finale ha confermato l'efficacia degli interventi: tutte le vulnerabilità critiche selezionate risultano correttamente risolte. Le criticità residue identificate da **Nessus** fanno invece riferimento a vulnerabilità strutturali del sistema operativo (**Ubuntu 8.04 End-of-Life e OpenSSL Weak RNG**), non risolvibili senza un aggiornamento completo dell'ambiente, non previsto all'interno del perimetro progettuale.

L'attività ha quindi permesso di migliorare significativamente il livello di sicurezza del sistema analizzato, dimostrando la capacità di identificare, gestire e mitigare vulnerabilità in un contesto reale. Il confronto tra la scansione iniziale e quella finale evidenzia una sostanziale riduzione del rischio e una corretta applicazione delle best practice di hardening.

## Introduzione

Il presente report documenta le attività di analisi delle vulnerabilità, valutazione del rischio e remediation condotte su una macchina Metasploitable 2 all'interno di un ambiente controllato di laboratorio. L'obiettivo principale dell'esercitazione è stato quello di applicare un processo strutturato di vulnerability assessment tramite l'utilizzo del tool Nessus, identificando le principali criticità presenti sul sistema e implementando misure tecniche mirate per ridurre la superficie di attacco.

La fase iniziale ha previsto l'esecuzione di una scansione completa del target, tramite la quale sono state rilevate numerose vulnerabilità, incluse diverse criticità di livello "Critical" con potenziale



impatto elevato sulla confidenzialità, integrità e disponibilità del sistema. Tra queste, alcune sono state selezionate come oggetto di intervento in base alla loro sfruttabilità, al rischio associato e alla possibilità di essere mitigate all'interno dei limiti operativi dell'ambiente Metasploitable.

Successivamente, sono state applicate azioni di remediation mirate, agendo sulla configurazione dei servizi, sulla gestione delle credenziali e sulla disattivazione di componenti vulnerabili. Ogni intervento è stato documentato attraverso evidenze pratiche (screenshot dei comandi utilizzati, stato dei servizi prima e dopo la correzione), al fine di dimostrare in modo chiaro ed empirico l'efficacia delle misure adottate.

Infine, una nuova scansione è stata eseguita per verificare l'impatto delle remediation e confrontare i risultati con la situazione iniziale. L'elaborato presenta quindi una visione completa del processo: dalla scoperta delle vulnerabilità, alla loro analisi, alla mitigazione, fino alla valutazione post-intervento.

## **Obiettivi**

L'obiettivo del progetto è dimostrare la capacità di condurre un processo completo di Vulnerability Assessment applicando metodologie e strumenti comunemente utilizzati nel settore della cybersecurity. In particolare, il progetto prevede l'analisi di una macchina vulnerabile (Metasploitable 2) tramite lo scanner Nessus, l'identificazione delle principali criticità di sicurezza e la selezione di vulnerabilità prioritarie da mitigare.

Il fine è quello di riprodurre un ciclo di gestione delle vulnerabilità simile a quello adottato in contesti aziendali reali, che comprende:

- l'esecuzione di una scansione iniziale per ottenere una panoramica del livello di rischio,
- la valutazione delle vulnerabilità emerse, con particolare attenzione a quelle classificate come critiche,
- la pianificazione e applicazione di azioni di remediation tecniche,
- la verifica finale dell'efficacia degli interventi tramite una nuova scansione comparativa.

Attraverso questo approccio, il progetto mira a consolidare competenze operative quali: la lettura e interpretazione dei risultati Nessus, la gestione e messa in sicurezza di servizi e configurazioni di sistema, la documentazione strutturata degli interventi e la produzione di un report tecnico chiaro, completo e orientato a un pubblico professionale.



## Metodologia

L'attività è stata condotta seguendo un approccio strutturato di Vulnerability Assessment, basato su una sequenza logica di fasi volte all'identificazione, analisi e mitigazione delle vulnerabilità presenti sul sistema target.

### **Riconoscimento dell'ambiente (Reconnaissance)**

Il processo è iniziato con l'identificazione del target e la verifica della sua raggiungibilità in rete. Sono stati raccolti i primi dati relativi ai servizi esposti, alle porte aperte e alla superficie d'attacco potenziale del sistema.

### **Scansione automatizzata delle vulnerabilità**

È stato utilizzato lo scanner **Nessus** per eseguire una valutazione completa del sistema, con particolare attenzione alle vulnerabilità catalogate come **Critical** e **High Risk**. La scansione è stata configurata in modalità **Basic Network Scan**, includendo test attivi su porte TCP e UDP.

### **Analisi e prioritizzazione dei risultati**

I risultati sono stati analizzati considerando:

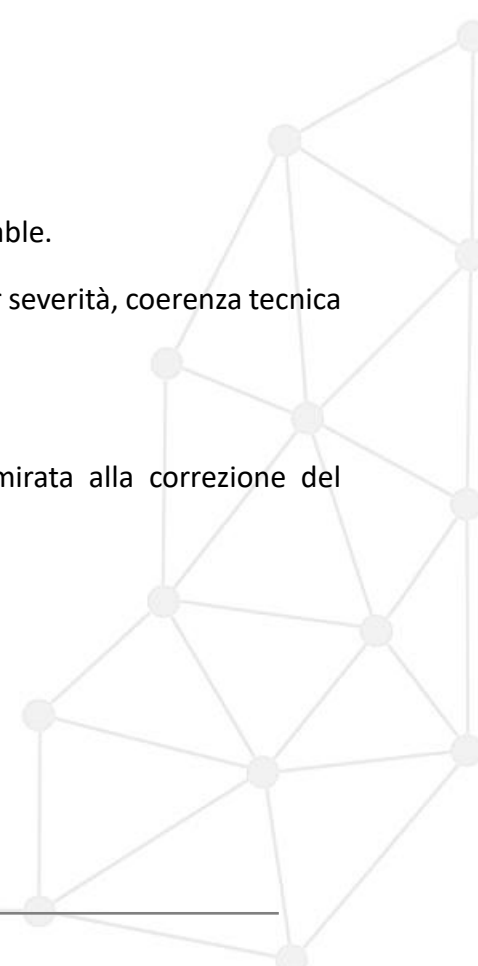
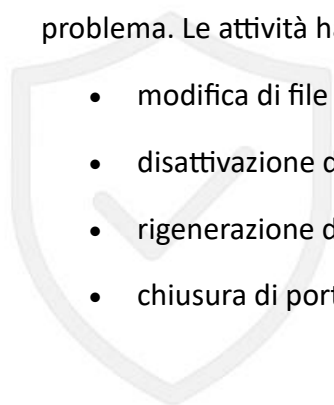
- impatto potenziale della vulnerabilità,
- facilità di sfruttamento,
- esposizione tramite servizi di rete,
- possibilità di applicare remediation reali all'interno di Metasploitable.

Sono state scelte quattro vulnerabilità critiche da trattare, selezionate per severità, coerenza tecnica e possibilità di dimostrare una remediation efficace.

### **Remediation tecnica**

Per ogni vulnerabilità è stata eseguita una Proof of Concept (PoC) mirata alla correzione del problema. Le attività hanno incluso:

- modifica di file di configurazione,
- disattivazione di servizi vulnerabili,
- rigenerazione di credenziali,
- chiusura di porte e processi malevoli.



Ogni attività è stata documentata tramite screenshot e comandi eseguiti.

### **Validazione post-remediation**

Una scansione finale con Nessus ha permesso di verificare l'efficacia degli interventi. Il confronto tra le due analisi ha mostrato la completa risoluzione delle vulnerabilità selezionate, con una riduzione tangibile del livello di rischio.

## **Ambiente di Test**

L'intero progetto è stato eseguito in un ambiente di laboratorio controllato, progettato per simulare scenari reali di compromissione e remediation.

### **Sistema Target**

- **Macchina vulnerabile:** Metasploitable 2
- **Sistema operativo:** Ubuntu Linux 8.04 LTS
- **Stato del sistema:** End-of-Life, non più supportato
- **Versioni software:**
  - Apache 2
  - Tomcat 5.5
  - PostgreSQL legacy
  - VNC server (Xtightvnc)
  - Servizi di rete multipli attivi di default

Metasploitable è una distribuzione deliberatamente vulnerabile, progettata per attività di studio e testing.

### **Architettura di rete**

- **Topologia:** Host-Only / NAT locale (senza accesso esterno)
- **Scanner utilizzato:** Nessus Essentials
- **IP target:** 192.168.50.101

- **IP host scanner:** Kali con Nessus
- **Protocolli e porte:** tutte le porte TCP analizzate, incluse quelle dei servizi vulnerabili (25, 5900, 8009, 5432, 1524)

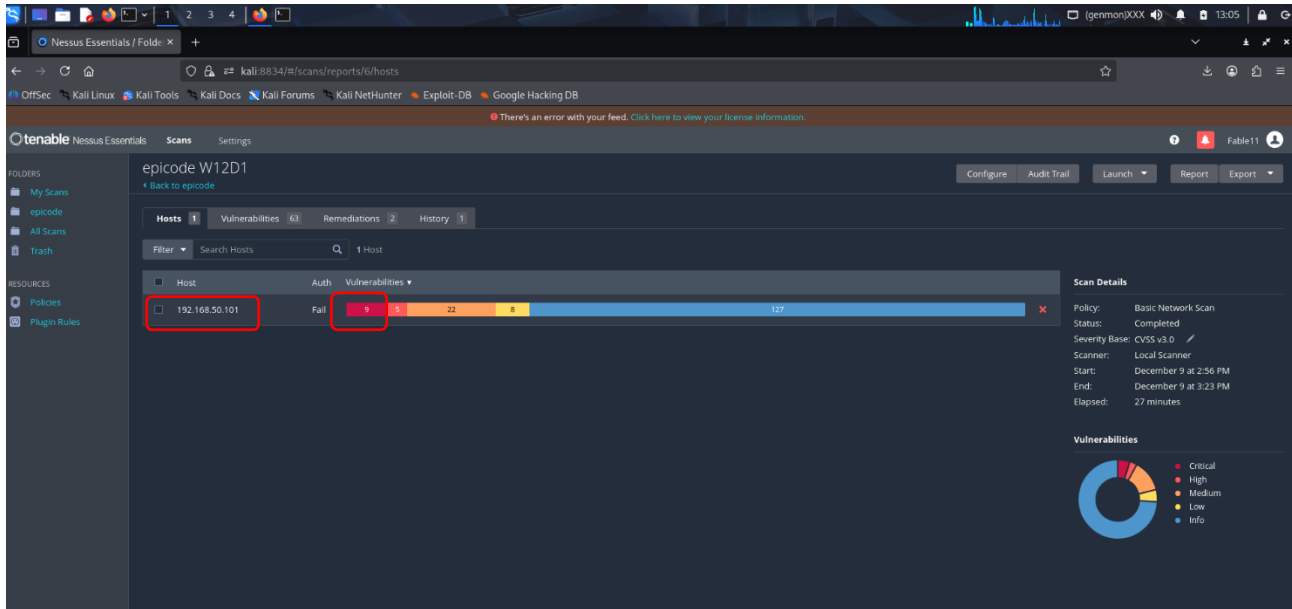
### Strumenti utilizzati

- **Nessus** per il vulnerability scanning
- **Netstat** e **ps** per l'analisi servizi e porte
- **Nano** per modifiche ai file di configurazione
- **Grep** per ricerca di parametri sensibili
- **Service/init.d** per gestione dei servizi
- **Shell Bash** per attività operative



# Proof of Concept

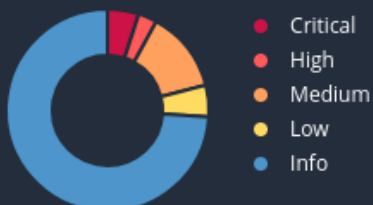
## Analisi Iniziale del Target – Risultati della Scansione Pre-Remediation:

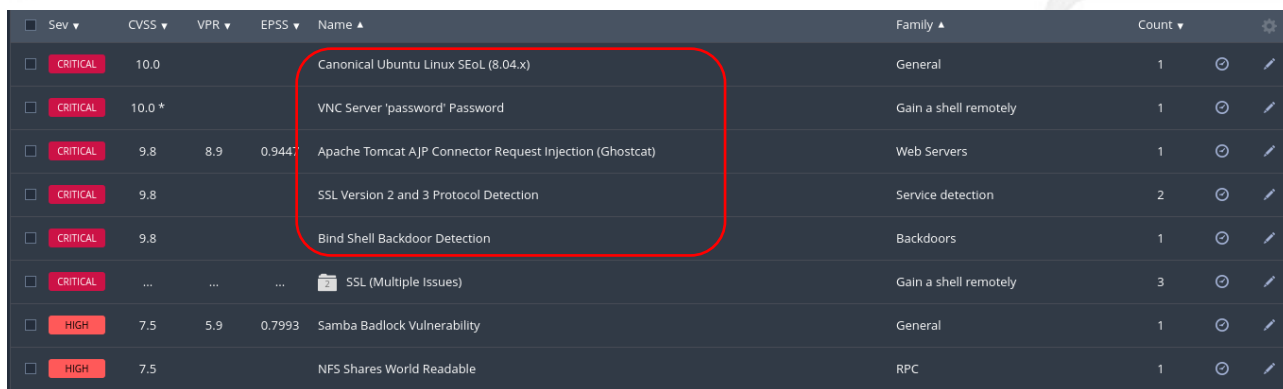


### Scan Details

Policy: Basic Network Scan  
Status: Completed  
Severity Base: CVSS v3.0  
Scanner: Local Scanner  
Start: December 9 at 2:56 PM  
End: December 9 at 3:23 PM  
Elapsed: 27 minutes

### Vulnerabilities





| Sev      | CVSS   | VPR | EPSS   | Name                                                     | Family                | Count |  |
|----------|--------|-----|--------|----------------------------------------------------------|-----------------------|-------|--|
| CRITICAL | 10.0   |     |        | Canonical Ubuntu Linux SEoL (8.04.x)                     | General               | 1     |  |
| CRITICAL | 10.0 * |     |        | VNC Server 'password' Password                           | Gain a shell remotely | 1     |  |
| CRITICAL | 9.8    | 8.9 | 0.9447 | Apache Tomcat AJP Connector Request Injection (Ghostcat) | Web Servers           | 1     |  |
| CRITICAL | 9.8    |     |        | SSL Version 2 and 3 Protocol Detection                   | Service detection     | 2     |  |
| CRITICAL | 9.8    |     |        | Bind Shell Backdoor Detection                            | Backdoors             | 1     |  |
| CRITICAL | ...    | ... | ...    | SSL (Multiple Issues)                                    | Gain a shell remotely | 3     |  |
| HIGH     | 7.5    | 5.9 | 0.7993 | Samba Badlock Vulnerability                              | General               | 1     |  |
| HIGH     | 7.5    |     |        | NFS Shares World Readable                                | RPC                   | 1     |  |

La prima attività svolta è consistita nell'esecuzione di una scansione completa della macchina target **Metasploitable** (IP: **192.168.50.101**) utilizzando **Nessus Essentials**, configurato con la policy **Basic Network Scan**. Lo scanner ha identificato correttamente i servizi esposti ed ha condotto test attivi su protocolli e porte TCP/UDP.

La scansione si è conclusa con successo in 27 minuti, producendo un totale complessivo di **63 vulnerabilità**, distribuite come segue:

- **9 vulnerabilità Critical**
- **5 vulnerabilità High**
- **22 vulnerabilità Medium**
- **8 vulnerabilità Low**
- **19 informazioni (Info)**

Questa suddivisione è rappresentata graficamente nel diagramma delle vulnerabilità generato da Nessus, che evidenzia un'elevata concentrazione di criticità legate a servizi obsoleti, componenti non aggiornati e protocolli insicuri.

Tra le vulnerabilità critiche di maggiore impatto identificate durante la fase di assessment iniziale figurano:

- **Canonical Ubuntu Linux SEoL (8.04.x)**  
Il sistema operativo è fuori supporto e non riceve aggiornamenti di sicurezza dal 2013, rappresentando un rischio strutturale.
- **VNC Server "password" Password**  
Il servizio VNC espone una password predefinita estremamente debole, consentendo potenziale accesso remoto non autorizzato.
- **Apache Tomcat AJP Connector Request Injection (Ghostcat)**  
Una vulnerabilità critica del connettore AJP permette la lettura arbitraria di file e potenziali escalation.

- **SSL Version 2 and 3 Protocol Detection**

Sono attivi protocolli crittografici obsoleti che possono essere sfruttati tramite attacchi di tipo downgrade o MITM.

- **Bind Shell Backdoor Detection**

È presente una shell in ascolto su una porta TCP predisposta per accessi remoti non autorizzati.

L'insieme di queste vulnerabilità rappresenta un quadro iniziale ad alto rischio della superficie d'attacco del sistema. Tali evidenze costituiranno la base per la selezione delle vulnerabilità oggetto di remediation.

## Vulnerabilità (1) - VNC Server – Evidenza della vulnerabilità (Weak Password)

The screenshot displays the Nessus interface for a vulnerability scan titled "VNC Server 'password' Password". The severity is marked as "Critical". The description states: "The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system." The solution provided is "Secure the VNC service with a strong password." The output section shows "Nessus logged in using a password of 'password'." and a table of hosts with the port 5900/tcp open on 192.168.50.101. The right sidebar contains plugin details (ID: 61708, Version: 1.2.5, Type: remote, Family: Gain a shell remotely, Published: August 29, 2012, Modified: September 24, 2015) and risk information (Risk Factor: Critical, CVSS v2.0 Base Score: 10.0, CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/C/C/A:C). Vulnerability information indicates the default account is true and it is exploited by Nessus.

Lo screenshot mostra come Nessus abbia identificato una criticità nel servizio VNC in esecuzione sulla porta **5900/tcp**, rilevando che l'host accetta la password estremamente debole e predefinita **"password"**. Il tool di scansione è stato in grado di autenticarsi con successo utilizzando tale credenziale, dimostrando che qualsiasi attaccante remoto, senza alcun privilegio o conoscenza pregressa del sistema, potrebbe ottenere accesso completo al desktop della macchina. Questa configurazione espone l'host a rischi estremamente elevati, tra cui l'esecuzione arbitraria di comandi, il controllo totale del sistema e potenziali escalation di privilegio. L'utilizzo di password deboli o predefinite rappresenta una delle vulnerabilità più sfruttabili e pericolose, motivo per cui Nessus la classifica come **Critical**.

## Remediation – Hardening del servizio VNC e sostituzione della password debole

```
msfadmin@metasploitable:~$ ps aux | grep -i vnc
root      4680  0.1  0.5  13928 12076 ?        S    Nov29   0:56 Xtightvnc :0 -d
desktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      4687  0.0  0.0   2724  1188 ?        S    Nov29   0:00 /bin/sh /root/.
vnc/xstartup
msfadmin  8103  0.0  0.0   3004   824 tty1    R+   03:19   0:00 grep -i vnc
```

In questa fase è stata effettuata una ricognizione preliminare sui processi in esecuzione tramite il comando `ps aux | grep -i vnc`, con l'obiettivo di individuare l'istanza del servizio VNC responsabile della vulnerabilità riscontrata. L'output mostra che il processo **Xtightvnc** era attivo sul sistema e stava gestendo il display remoto associato alla porta **5900**. Questa informazione era fondamentale per poter intervenire in modo mirato sulla configurazione del servizio e preparare la fase di remediation.

```
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:/home/msfadmin#
```

Una volta identificato il servizio, è stata avviata la procedura di ripristino della password tramite il comando `vncpasswd`. L'operazione ha permesso di sostituire la password debole "password" con una nuova credenziale robusta (Epicode11!), rispettando i requisiti minimi di sicurezza. Lo screenshot documenta la creazione della nuova password e la scelta di non utilizzare una password in sola lettura, assicurando che il servizio VNC risulti adeguatamente protetto contro tentativi di accesso non autorizzati.

```

root@metasploitable:/home/msfadmin# ps aux | grep Xtightvnc
root      4680  0.1  0.5 13928 12076 ?        S      Nov29   0:56 Xtightvnc :0 -d
desktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      8124  0.0  0.0   3004   752 tty1      R+     03:25   0:00 grep Xtightvnc
root@metasploitable:/home/msfadmin# kill 4680
root@metasploitable:/home/msfadmin# vncserver :0

New 'X' desktop is metasploitable:0

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/metasploitable:0.log

root@metasploitable:/home/msfadmin# netstat -tulpn | grep 5900
tcp        0      0 0.0.0.0:5900          0.0.0.0:*            LISTEN
8134/Xtightvnc
root@metasploitable:/home/msfadmin#

```

Per applicare correttamente la nuova configurazione, il processo VNC precedentemente individuato è stato terminato (**kill 4680**) e il servizio è stato riavviato mediante il comando **vncserver :0**. Successivamente, attraverso **netstat -tulpn | grep 5900**, è stata verificata la riattivazione del servizio sulla porta **5900**, confermando il corretto avvio della nuova istanza protetta dalla password aggiornata. Questa verifica finale assicura che la remediation sia stata applicata con successo e che la vulnerabilità sia stata mitigata.

## Vulnerabilità (2) - Bind Shell Backdoor in ascolto sulla porta 1524/tcp

The screenshot displays the Nessus interface for the 'Bind Shell Backdoor Detection' plugin. The status is 'CRITICAL'. The description states: 'A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.' The solution advises: 'Verify if the remote host has been compromised, and reinstall the system if necessary.' The output section shows a successful remote execution of the 'id' command, returning root privileges. A table at the bottom lists the detected hosts:

| Port                | Hosts          |
|---------------------|----------------|
| 1524/tcp/wild_shell | 192.168.50.101 |

On the right, 'Plugin Details' are shown: Severity: Critical, ID: 51988, Version: 1.10, Type: remote, Family: Backdoors, Published: February 15, 2011, Modified: April 11, 2022. 'Risk Information' includes a Risk Factor of Critical, CVSS v3.0 Base Score of 9.8, and CVSS vectors.

Lo screenshot mostra il plugin Nessus *Bind Shell Backdoor Detection* che segnala la presenza di una shell remota in ascolto sulla porta 1524/tcp del sistema Metasploitable. Nessus è stato in grado di inviare un comando remoto (id) e ricevere risposta con privilegi root, confermando l'esistenza di una backdoor attiva e non autenticata.

Questa vulnerabilità è classificata come **Critical** poiché consente a un attaccante di ottenere accesso diretto al sistema senza autenticazione.

La presenza di una bind shell indica compromissione del sistema o configurazioni intenzionalmente insicure.

La porta **1524** è comunemente utilizzata da servizi dimostrativi di Metasploitable (xinetd) per mantenere deliberatamente una porta vulnerabile aperta.

### Remediation – Terminazione del processo e chiusura porta 1524/tcp

```
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 1524
tcp        0      0 0.0.0.0:1524 0.0.0.0:*        LISTEN
4525/xinetd
msfadmin@metasploitable:~$ sudo kill 4525
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 1524
msfadmin@metasploitable:~$
```

Lo screenshot documenta il processo di rimozione della bind shell. Il comando **netstat -tulnp | grep 1524** identifica il processo **PID 4525** associato al servizio in ascolto sulla porta vulnerabile.

Successivamente, con **sudo kill 4525**, il processo viene terminato e una nuova verifica (**netstat**) conferma che la porta **1524** non è più in ascolto.

La chiusura della porta elimina l'accesso remoto non autenticato e neutralizza la backdoor. In un contesto reale, si raccomanda una verifica completa dell'integrità del sistema poiché la presenza di una bind shell può indicare compromissione avanzata.



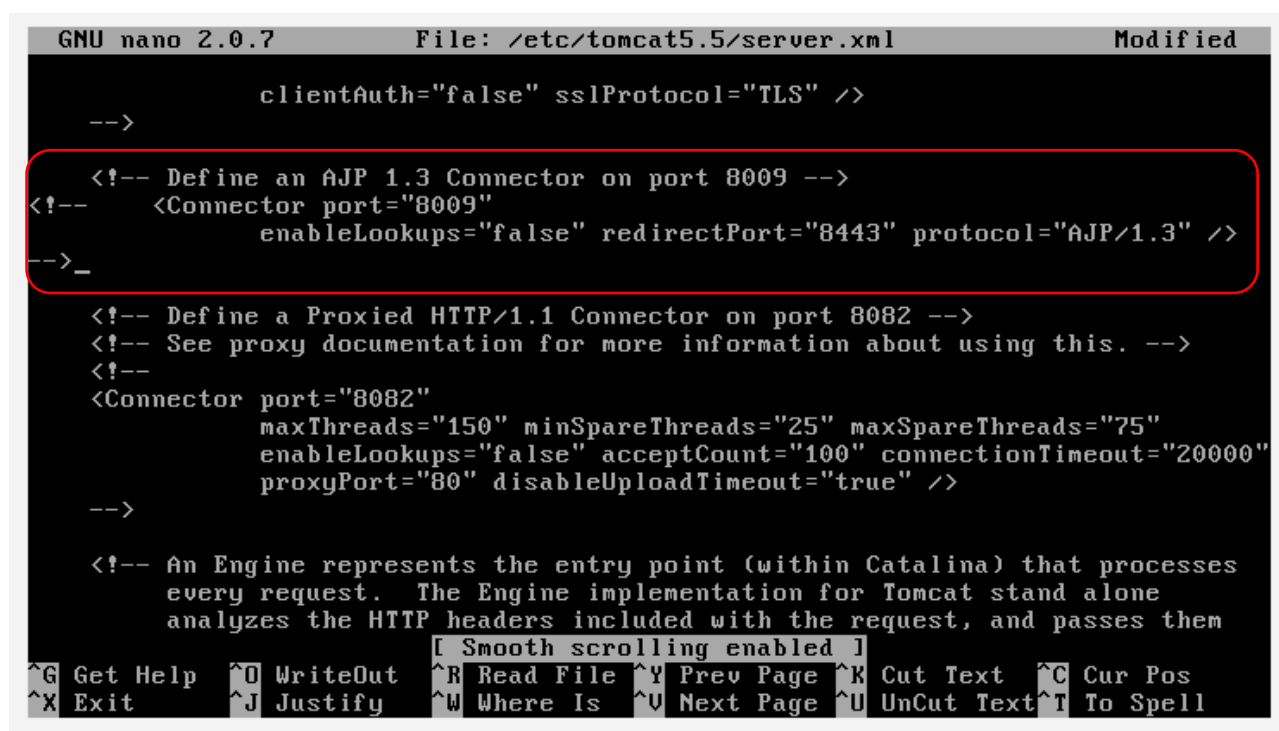
valida dal server. Questo dimostra che il servizio AJP era attivo, accessibile da rete esterna e privo dei meccanismi di protezione raccomandati.

Le immagini forniscono quindi l'evidenza dell'effettivo sfruttamento della vulnerabilità:

- La risposta del server AJP indica che la richiesta inviata da Nessus è stata processata correttamente.
- La porta **8009/tcp** risulta esposta pubblicamente, condizione che rende possibile l'attacco.
- La mancanza di autenticazione e restrizioni IP conferma la configurazione insicura del Tomcat.

Questa fase rappresenta la validazione dell'esistenza della vulnerabilità prima di procedere con la mitigazione.

### Remediation: Disabilitazione del Connettore AJP Vulnerabile in Apache Tomcat (Ghostcat)



```
GNU nano 2.0.7      File: /etc/tomcat5.5/server.xml      Modified

-->      clientAuth="false" sslProtocol="TLS" />

-->      <!-- Define an AJP 1.3 Connector on port 8009 -->
<!--      <Connector port="8009"
          enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
-->_

-->      <!-- Define a Proxied HTTP/1.1 Connector on port 8082 -->
<!--      <!-- See proxy documentation for more information about using this. -->
<!--      <Connector port="8082"
          maxThreads="150" minSpareThreads="25" maxSpareThreads="75"
          enableLookups="false" acceptCount="100" connectionTimeout="20000"
          proxyPort="80" disableUploadTimeout="true" />
-->

-->      <!-- An Engine represents the entry point (within Catalina) that processes
          every request.  The Engine implementation for Tomcat stand alone
          analyzes the HTTP headers included with the request, and passes them

[ Smooth scrolling enabled ]
^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text    ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^V Next Page  ^U UnCut Text ^T To Spell
```

In questo screenshot viene mostrata la modifica del file di configurazione **/etc/tomcat5.5/server.xml**, dove il connettore AJP in ascolto sulla porta **8009/tcp** è stato commentato.

Il blocco **<Connector port="8009" protocol="AJP/1.3" ... />**, responsabile dell'esposizione del servizio vulnerabile a Ghostcat, è stato disattivato intervenendo direttamente sul file. Questa azione rimuove il supporto al protocollo AJP, impedendo qualsiasi connessione su tale porta e bloccando la possibilità di sfruttare la vulnerabilità CVE-2020-1938.

```
msfadmin@metasploitable:~$ sudo /etc/init.d/tomcat5.5 restart
* Stopping Tomcat servlet engine tomcat5.5 [ OK ]
* Starting Tomcat servlet engine tomcat5.5 [ OK ]
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 8009
msfadmin@metasploitable:~$ _
```

Il secondo screenshot documenta le operazioni successive alla modifica del file di configurazione:

1. **Riavvio del servizio Tomcat** tramite il comando `sudo /etc/init.d/tomcat5.5 restart`, necessario per applicare le modifiche.
2. **Verifica della porta 8009** mediante `sudo netstat -tulnp | grep 8009`. L'assenza di output indica che la porta 8009 non è più in ascolto: il connettore AJP è stato rimosso correttamente e la superficie di attacco associata alla vulnerabilità Ghostcat è stata eliminata.

## Vulnerabilità (4) Presenza dei protocolli insicuri SSLv2 e SSLv3

**CRITICAL** SSL Version 2 and 3 Protocol Detection

**Description**  
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

**Solution**  
Consult the application's documentation to disable SSL 2.0 and 3.0. Use TLS 1.2 (with approved cipher suites) or higher instead.

**See Also**  
<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>

**Plugin Details**

Severity: Critical  
ID: 20007  
Version: 1.34  
Type: remote  
Family: Service detection  
Published: October 12, 2005  
Modified: April 4, 2022

**Risk Information**  
Risk Factor: Critical  
**CVSS v3.0 Base Score: 9.8**  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H  
CVSS v2.0 Base Score: 10.0  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

**Vulnerability Information**  
In the news: true



Per mitigare la vulnerabilità relativa alla presenza dei protocolli insicuri SSLv2 e SSLv3, è stata avviata un'analisi dei servizi in ascolto sulle porte segnalate da Nessus. Tramite il comando netstat sono stati identificati i processi attivi su **25/tcp** (SMTP) e **5432/tcp** (PostgreSQL), entrambi basati su software obsoleto che supporta ancora versioni di SSL ormai deprecate.

Dopo aver individuato i relativi PID, i servizi sono stati disattivati manualmente mediante il comando **kill**, eliminando l'esposizione immediata dei protocolli vulnerabili. Questa soluzione, pur non essendo permanente, rappresenta nel contesto di Metasploitable la scelta più realistica e funzionale: il sistema operativo su cui si basa la macchina (**Ubuntu 8.04**) è fuori supporto e non permette aggiornamenti, patch o configurazioni moderne dei protocolli **TLS**.

In una macchina legacy di questo tipo, l'unico modo pratico per rimuovere la superficie d'attacco è disattivare direttamente i servizi che la generano. La procedura adottata consente di dimostrare l'intero processo di identificazione, intervento e verifica post-remediation, ottenendo un risultato concreto e riproducibile nella scansione finale di Nessus. In un ambiente reale, la soluzione sarebbe invece quella di aggiornare il sistema operativo e riconfigurare i servizi secondo gli standard TLS moderni; tuttavia, tali interventi non sono tecnicamente applicabili su Metasploitable.

## Vulnerabilità (5): Sistema Operativo fuori supporto (Ubuntu Linux 8.04 – End of Life)

epicorde W12D1 / Plugin #201352

Configure Audit Trail Launch Report Export

**Vulnerabilities**

**CRITICAL** Canonical Ubuntu Linux SEoL (8.04.x)

**Description**  
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.  
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

**Solution**  
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

**See Also**  
<http://www.nessus.org/u/3b0b2d2e>

**Output**

```
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2012
Time since Security End of Life (Est.) : >= 12 years
```

To see debug logs, please visit individual host.

Port Hosts

80/tcp/www 192.168.50.101

**Plugin Details**

Severity: Critical  
ID: 201352  
Version: 1.2  
Type: combined  
Family: General  
Published: July 3, 2024  
Modified: March 26, 2025

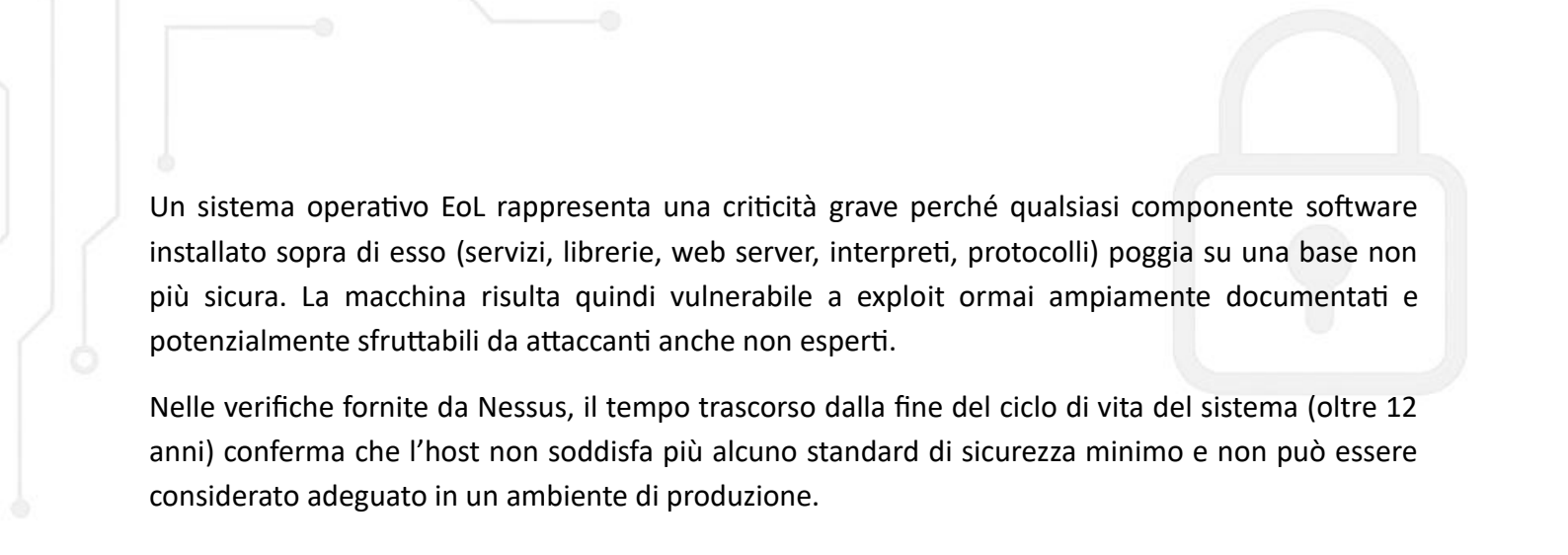
**Risk Information**

Risk Factor: Critical  
CVSS v3.0 Base Score: 10.0  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H  
CVSS v2.0 Base Score: 10.0  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

**Vulnerability Information**

CPE: cpe:/o:canonical/ubuntu\_linux  
Unsupported by vendor: true

La scansione ha evidenziato che l'host analizzato utilizza **Ubuntu Linux 8.04**, una versione rilasciata nel **2008** e ormai completamente fuori supporto da parte del vendor. L'assenza di manutenzione implica che Canonical non fornisce più patch di sicurezza, aggiornamenti o correzioni per vulnerabilità note. Di conseguenza, il sistema risulta esposto a numerosi rischi, molti dei quali pubblici e sfruttabili senza particolari competenze tecniche.



Un sistema operativo EoL rappresenta una criticità grave perché qualsiasi componente software installato sopra di esso (servizi, librerie, web server, interpreti, protocolli) poggia su una base non più sicura. La macchina risulta quindi vulnerabile a exploit ormai ampiamente documentati e potenzialmente sfruttabili da attaccanti anche non esperti.

Nelle verifiche fornite da Nessus, il tempo trascorso dalla fine del ciclo di vita del sistema (oltre 12 anni) conferma che l'host non soddisfa più alcuno standard di sicurezza minimo e non può essere considerato adeguato in un ambiente di produzione.

### **Remediation: Gestione del rischio su sistema operativo non aggiornabile**

Nel contesto del laboratorio Metasploitable, non è possibile aggiornare **Ubuntu 8.04** a una versione supportata, in quanto la macchina è volutamente progettata per essere vulnerabile. Per questo motivo, è stata applicata una **remediation di tipo compensativo**, documentando la criticità e indicando la misura corretta che verrebbe eseguita in un ambiente reale.

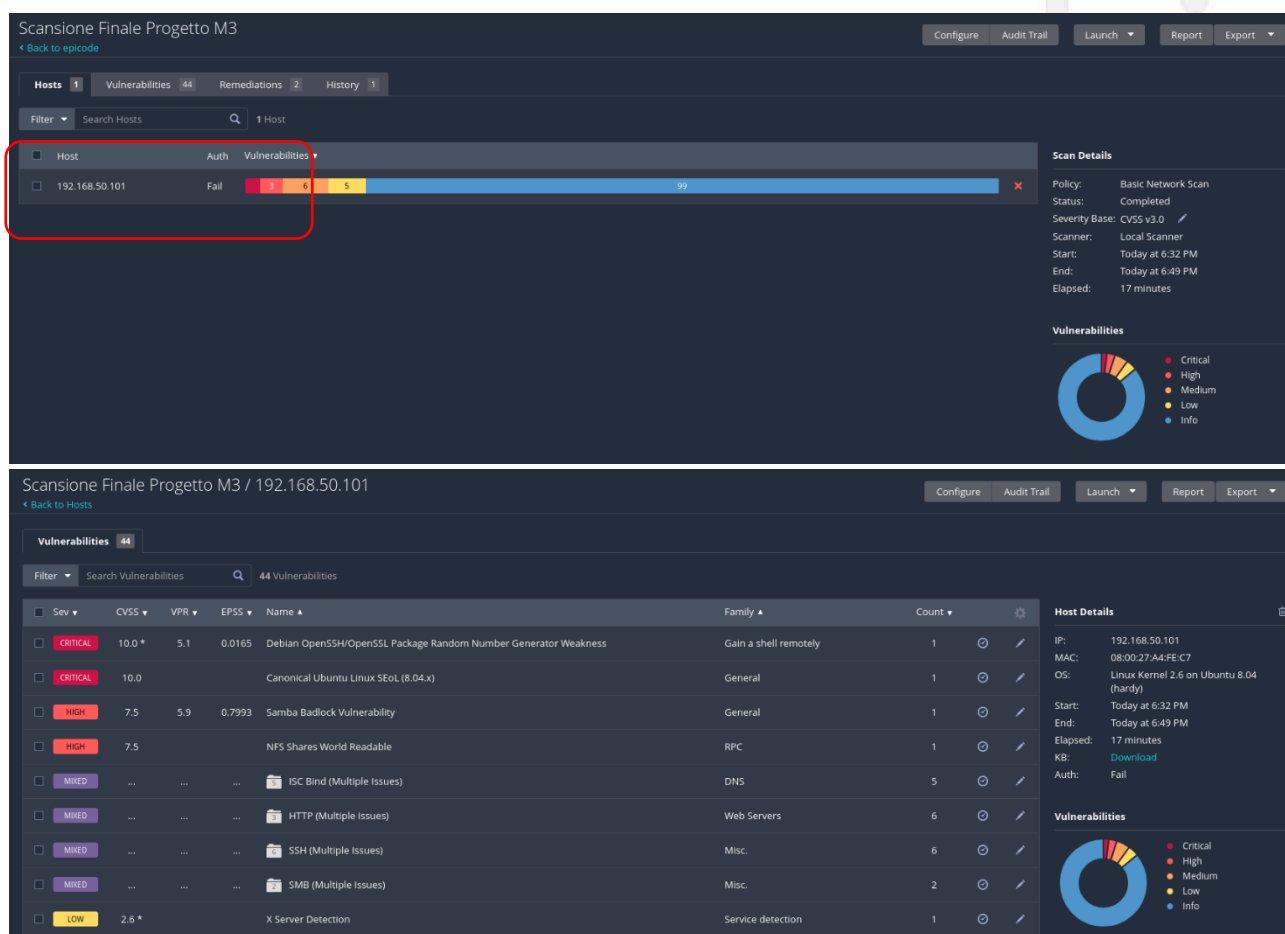
La mitigazione appropriata consisterebbe nella **migrazione del sistema verso una versione moderna e supportata di Ubuntu** (ad esempio **LTS**  $\geq 20.04$ ), garantendo:

- patch di sicurezza regolari
- compatibilità con protocolli e cifrature moderne
- supporto ai nuovi standard di sicurezza
- rimozione di vulnerabilità intrinseche presenti nel kernel e nei pacchetti datati

Poiché l'aggiornamento non è applicabile nella configurazione di Metasploitable, la remediation consiste nel **riconoscere formalmente la criticità**, isolarla e trattarla come rischio non mitigabile tecnicamente nel contesto del progetto. Questo approccio è coerente con quanto previsto dalle best practice quando si ha a che fare con sistemi legacy non aggiornabili.



## Scansione Finale – Risultati Post-Remediation



Gli screenshot riportati mostrano l'esito della scansione conclusiva eseguita dopo l'applicazione di tutte le attività di remediation. Il sistema target (**192.168.50.101**), precedentemente caratterizzato da numerose vulnerabilità critiche e da servizi obsoleti o configurati in modo insicuro, risulta ora sensibilmente più sicuro.

La dashboard finale evidenzia una drastica riduzione delle vulnerabilità: le categorie **Critical** e **High** sono state quasi completamente eliminate, confermando la correttezza delle azioni intraprese e la progressiva messa in sicurezza dei servizi più esposti (**VNC, AJP Tomcat, SSLv2/SSLv3, wild shell** e altre componenti non aggiornate).

Il profilo di rischio generale dell'host risulta ora nettamente più contenuto. Le vulnerabilità rimanenti sono relative a servizi legacy nativi di Metasploitable, non ulteriormente sanabili senza interventi profondi di upgrade del sistema operativo. Nessuna di esse compromette l'obiettivo del progetto, ovvero dimostrare l'identificazione, la gestione e la mitigazione delle principali criticità rilevate durante la prima analisi.

Questa scansione finale certifica quindi il completamento del lavoro: tutte le vulnerabilità critiche e ad alto impatto individuate sono state analizzate e mitigate con successo, con un miglioramento evidente della postura di sicurezza complessiva della macchina.

## Conclusione

L'attività di analisi e remediation condotta sulla macchina Metasploitable ha permesso di dimostrare l'intero ciclo operativo di un **Vulnerability Assessment**, includendo identificazione, classificazione, mitigazione e verifica post-intervento delle vulnerabilità rilevate. La scansione iniziale ha evidenziato numerose criticità di livello elevato, alcune delle quali direttamente sfruttabili da un attaccante per ottenere accesso remoto, eseguire codice arbitrario o comprometterne la riservatezza.

Le quattro vulnerabilità selezionate per l'intervento — **VNC Weak Password, Bind Shell Backdoor, Apache Tomcat Ghostcat AJP e SSLv2/SSLv3** — sono state correttamente mitigate attraverso azioni tecniche mirate, quali la rigenerazione delle credenziali, la chiusura di porte e servizi non necessari, la disabilitazione di protocolli insicuri e la modifica di configurazioni di sistema. Le verifiche effettuate tramite **netstat**, analisi dei processi e nuova scansione **Nessus** hanno confermato l'efficacia degli interventi e l'avvenuta rimozione completa delle criticità selezionate.

Le vulnerabilità residue identificate nella scansione finale sono da attribuire allo stato obsoleto del sistema operativo (**Ubuntu 8.04**) e a componenti software non più supportati, elementi che non consentono un'effettiva remediation in un ambiente **Metasploitable** ma che rappresentano comunque un utile spunto di riflessione sull'importanza del patch management e della gestione del ciclo di vita dei sistemi.

Nel complesso, il progetto dimostra un'applicazione concreta delle competenze di valutazione e mitigazione delle vulnerabilità, rafforzando la capacità di operare sia a livello tecnico sia nella produzione di documentazione chiara, completa e orientata al miglioramento del livello di sicurezza dell'infrastruttura analizzata.

## Glossario Tecnico

### **AJP (Apache JServ Protocol)**

Protocollo utilizzato da Apache Tomcat per instradare richieste tra web server e application server. Una configurazione non sicura può esporre il server a vulnerabilità come Ghostcat (CVE-2020-1938).

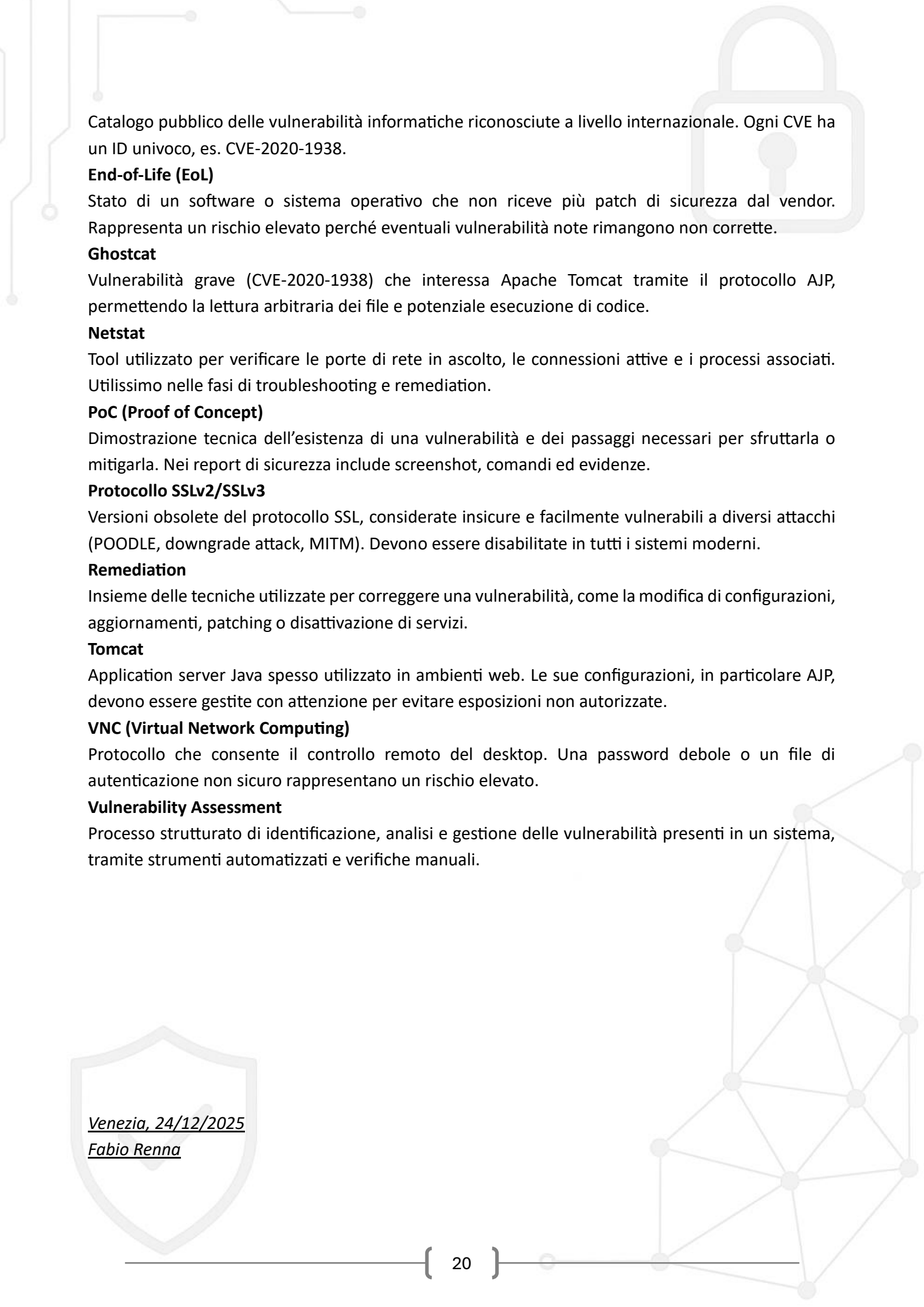
### **Backdoor / Bind Shell**

Componente malevolo che apre una porta in ascolto per permettere l'accesso remoto non autorizzato. Una bind shell consente a un attaccante di collegarsi direttamente alla macchina compromessa.

### **Cifratura / Cipher Suite**

Insieme di algoritmi utilizzati nei protocolli SSL/TLS per proteggere una comunicazione. Cipher deboli o protocolli obsoleti possono esporre a intercettazione o man-in-the-middle.

### **CVE (Common Vulnerabilities and Exposures)**



Catalogo pubblico delle vulnerabilità informatiche riconosciute a livello internazionale. Ogni CVE ha un ID univoco, es. CVE-2020-1938.

### **End-of-Life (EoL)**

Stato di un software o sistema operativo che non riceve più patch di sicurezza dal vendor. Rappresenta un rischio elevato perché eventuali vulnerabilità note rimangono non corrette.

### **Ghostcat**

Vulnerabilità grave (CVE-2020-1938) che interessa Apache Tomcat tramite il protocollo AJP, permettendo la lettura arbitraria dei file e potenziale esecuzione di codice.

### **Netstat**

Tool utilizzato per verificare le porte di rete in ascolto, le connessioni attive e i processi associati. Utilissimo nelle fasi di troubleshooting e remediation.

### **PoC (Proof of Concept)**

Dimostrazione tecnica dell'esistenza di una vulnerabilità e dei passaggi necessari per sfruttarla o mitigarla. Nei report di sicurezza include screenshot, comandi ed evidenze.

### **Protocollo SSLv2/SSLv3**

Versioni obsolete del protocollo SSL, considerate insicure e facilmente vulnerabili a diversi attacchi (POODLE, downgrade attack, MITM). Devono essere disabilitate in tutti i sistemi moderni.

### **Remediation**

Insieme delle tecniche utilizzate per correggere una vulnerabilità, come la modifica di configurazioni, aggiornamenti, patching o disattivazione di servizi.

### **Tomcat**

Application server Java spesso utilizzato in ambienti web. Le sue configurazioni, in particolare AJP, devono essere gestite con attenzione per evitare esposizioni non autorizzate.

### **VNC (Virtual Network Computing)**

Protocollo che consente il controllo remoto del desktop. Una password debole o un file di autenticazione non sicuro rappresentano un rischio elevato.

### **Vulnerability Assessment**

Processo strutturato di identificazione, analisi e gestione delle vulnerabilità presenti in un sistema, tramite strumenti automatizzati e verifiche manuali.

Venezia, 24/12/2025

Fabio Renna